

Zusammenfassung

In dem zweiten Kapitel

- beschreiben wir zunächst die in diesem Buch näher betrachteten Sicherungsverfahren im Online-Banking
 - die PIN/TAN-Verfahren TAN-Liste, iTAN, SMS-TAN und Chip-TAN sowie
 - signaturbasierte HBCI-Verfahren mit Chipkarte oder mit Dateien,
- betrachten auf der Basis von Umfragen deren Nutzung seit 2008
- sowie die Häufigkeit des Angebots in einer selbst erhobenen Stichprobe von 30 Banken im Jahr 2014,
- bewerten deren Sicherheit nach Einschätzungen in den Medien, einer Studie der European Union Agency for Network and Information Security (ENISA) und des EU-Projekts STORK und
- stellen diese Sicherheitsbewertung der Verfahren ihrer Verbreitung gegenüber.

Dabei bestätigt sich die eingangs formulierte These, dass die sichereren HBCI-Verfahren im Verhältnis zu den PIN/TAN-Verfahren deutlich seltener angeboten und noch seltener genutzt werden.

Inzwischen gibt es in Deutschland mehr als ein Dutzend unterschiedliche Verfahren zur Sicherung der Transaktionen im Online-Banking im Privatkundenbereich. Sie betreffen im Gegensatz zum Abheben von Geld am Geldautomaten oder Bezahlen mit Karten in Geschäften (Point of Sale) zwei miteinander verbundene Vorgänge, die unterschiedliche

Funktionen erfüllen. Sie sollen aus der Sicht des Finanzinstitutes zum einen bei der Anmeldung die Identität des Nutzers als Kontoinhaber überprüfen (Authentifizierung) und zum anderen die konkrete Transaktion autorisieren, so wie ein Überweisungsauftrag sonst auf einem Formular unterschrieben werden muss.

Die dafür angebotenen Verfahren können eingeteilt werden in PIN/TAN-basierte und signaturbasierte Verfahren (Zöhrer 2010; Borges et al. 2011). In der folgenden Rekonstruktion der bisherigen Entwicklung konzentrieren wir uns auf vier PIN/TAN- und drei Signaturverfahren. Im abschließenden Ausblick gehen wir auch auf neuere Varianten ein.

2.1 PIN/TAN-Verfahren und HBCI-Verfahren im Überblick

Bei den PIN/TAN-basierten Verfahren erfolgt die Anmeldung mittels Benutzerkennung und einem Passwort, der sogenannten PIN (Personal Identification Number). Die Durchführung einer Transaktion wird durch ein weiteres Passwort abgesichert, durch eine einmal gültige Transaktionsnummer (TAN). Während die PIN dem Kontoinhaber dauerhaft zugeordnet ist und explizit geändert werden muss, fungiert die aus sechs bis acht Ziffern und teilweise auch aus Buchstaben bestehende TAN als Einmalpasswort. Finanzinstitut und Kunde verfügen entweder über eine Liste gültiger TANs oder die TAN wird während der jeweiligen Transaktion erzeugt. Tabelle 2.1 listet verschiedene PIN/TAN-Verfahren auf, deren Entwicklung und Verbreitung im Weiteren näher untersucht wird.

Bei den signaturbasierten Verfahren erfolgt die Sicherung der Anmelde- und Transaktionsdaten auf der Basis digitaler Schlüssel, die wie eine Unterschrift eine Zuordnung von Daten zu einer Person gewährleisten sollen. Eine so eindeutige Verknüpfung von Daten mit einem Sicherheitsmerkmal, wie einem digitalen Schlüssel, ist bei der Verwendung von TANs nicht per se gegeben. Ein weiterer Unterschied ist, dass digitale Schlüssel nur einmal vor der ersten Verwendung ausgetauscht werden müssen, TANs müssen hingegen bei jedem Vorgang zwischen Finanzinstitut und Kunde übertragen werden und sind dadurch leichter angreifbar. Wie PIN und TAN sind die Schlüssel Geheimnisse, die nur dem Finanzinstitut und/oder dem Kunden bekannt sind. Dabei wird unterschieden zwischen symmetrischen Verfahren, bei denen Finanzinstitut und Kunde über denselben Schlüssel verfügen, und asymmetrischen Verfahren, bei denen Finanzinstitut und Kunde jeweils eigene Schlüsselpaare besitzen, die aus einem geheimen persönlichen und einem öffentlichen Schlüssel bestehen. Der Schlüssel wird den Kunden auf einer Chipkarte oder als Datei auf einem Datenträger, wie z. B. einem USB-Stick, zur Verfügung gestellt. Der Zugriff auf die Schlüssel ist durch eine PIN geschützt. Trotz gleicher Bezeichnung ist dies nicht die PIN, die in PIN/TAN-Verfahren zur Anmeldung am Online-Portal verwendet wird. Heute werden diese Bankensignaturkarten und -dateien nur noch von den Kreditinstituten selbst angeboten und bis auf vereinzelte Ausnahmen nur im

Tab.2.1 Verschiedene PIN/TAN-Verfahren im Online-Banking

PIN/TAN Sicherungsverfahren	
TAN-Liste	In dem 1984 eingeführten PIN/TAN-Verfahren weist das Finanzinstitut dem Kunden eine PIN zu und erstellt eine Liste mit Transaktionsnummern, die per Briefpost zugestellt wird. Der Kunde meldet sich unter Verwendung einer Benutzerkennung sowie der PIN am Bankportal an und erhält Informationen zu seinem Konto. Die Durchführung einer Transaktion erfordert die Angabe einer beliebig ausgewählten Transaktionsnummer von der vorab zugestellten TAN-Liste. Die TAN verliert nach ihrer Verwendung ihre Gültigkeit. Geht der Vorrat an TANs zur Neige, bekommt der Kunde automatisch oder auf Anforderung eine neue TAN-Liste.
iTAN	iTAN steht für indizierte TAN. Auf der Liste ist jeder TAN eine laufende Nummer zugeordnet. Bei jeder Transaktion gibt das Finanzinstitut durch eine Nummer vor, welche TAN für die aktuelle Transaktion zu verwenden ist. Somit ist pro Transaktion zu einem Zeitpunkt jeweils nur genau eine TAN gültig, wodurch Angriffe auf das iTAN-Verfahren im Vergleich zur TAN-Liste erschwert werden.
SMS-TAN	Im SMS-TAN-Verfahren (auch smsTAN, mTAN oder mobileTAN) wird auf den Einsatz einer vorab erstellten TAN-Liste verzichtet. Der Kunde erhält nach Absenden der Daten einer Transaktion eine vom Finanzinstitut generierte, zeitlich begrenzt gültige TAN per SMS an ein zuvor registriertes Mobiltelefon zugeschickt. Dabei kann die SMS zusätzlich auch Transaktionsdaten, wie Betrag oder Kontonummer des Empfängers enthalten.
ChipTAN	Statt von dem Finanzinstitut auf das Mobiltelefon geschickt zu werden, kann die benötigte TAN auch während der Transaktion auf einem Gerät vom Kunden erzeugt werden. Dazu erhält der Kunde entweder per Post oder in der Filiale ein Gerät von der Größe eines kleinen Taschenrechners mit einem Schlitz für den Einschub seiner Bank- oder Sparkassenkarte. Der TAN-Generator im Chip der Kundenkarte errechnet aus den Transaktionsdaten und den Daten der Kundenkarte eine TAN und stellt diese auf der Anzeige des Zusatzgerätes dar. Der Kunde gibt diese TAN in ein Online-Formular im Browser ein und schickt sie an das Finanzinstitut, wo diese TAN mit einer nach demselben Verfahren errechneten TAN verglichen wird. Eine manuelle Übertragung der Transaktionsdaten in das ChipTAN-Gerät entfällt bei dem heute üblichen Flickercode-Verfahren. Nach Eingabe der Transaktionsdaten in das Online-Formular im Browser wird ein Schwarz-Weiß-Bild mit 5 Balken erzeugt, ähnlich dem Barcode auf Markenartikeln. Durch Ein- und Ausschalten der Balken werden Lichtsignale erzeugt, mittels derer die Transaktionsdaten an ein ChipTAN-Gerät mit optischer Schnittstelle übertragen werden können.

Online-Banking eingesetzt. Insgesamt werden drei in Tab. 2.2 beschriebene Verfahren verwendet, die 1998 im HBCI-Standard definiert und mit diesem eingeführt wurden. Dieser Standard wird seit 2003 unter der Bezeichnung Financial Transaction Services (FinTS) weiterentwickelt. Die ehemaligen HBCI-Sicherungsverfahren und die PIN/TAN-Verfahren bilden seitdem als „FinTS HBCI“ und „FinTS PIN/TAN“ gemeinsam den Teil „FinTS Security“ (Deutsche Kreditwirtschaft 2015). In der Praxis blieben jedoch die alten Bezeichnungen der Sicherungsverfahren gebräuchlich.

Tab.2.2 Signaturbasierte HBCI-Verfahren

Signaturbasierte HBCI-Verfahren	
DDV mit Chipkarte – gemeinsamer Schlüssel auf Chipkarte – einfache digitale Signatur	DDV (= DES-DES-Verfahren) steht für symmetrisches Verfahren, bei dem Finanzinstitut und Kunde über denselben Schlüssel verfügen. Die Bezeichnung leitet sich aus der mehrfachen Verwendung des Verschlüsselungsalgorithmus Data Encryption Standard (DES) ab. Das Finanzinstitut leitet kundenindividuelle Schlüssel aus einem Hauptschlüssel (Masterkey) ab, die auf eine Chipkarte kopiert werden. Diese wird dem Kunden zusammen mit einer PIN übergeben, die für den Zugriff auf die Schlüssel erforderlich ist. Sowohl bei der Anmeldung als auch bei der Transaktionsabsicherung müssen Kunden die Chipkarte in einen angeschlossenen Kartenleser einlegen und die zur Karte gehörende PIN eingeben. Anschließend werden die Daten unter Verwendung symmetrischer Kryptographie verschlüsselt und mit einem Nachrichtenauthentifizierungscode (MAC, Message Authentication Code) versehen. Die kryptographischen Prozesse werden auf der Chipkarte durchgeführt. Da das Finanzinstitut über denselben Schlüssel verfügt, können die Transaktionsdaten dort entschlüsselt werden. Aus diesem Grund kann die Herkunft der Signatur allerdings auch nicht allein dem Kunden zugeordnet werden, da hierfür formal auch das Finanzinstitut in Frage kommt. Die Zuordnung zum Kunden basiert auf dem Vertrauensverhältnis zwischen dem Finanzinstitut und dem Kunden, das einen Missbrauch durch das Finanzinstitut ausschließt.
RDH mit Chipkarte – Schlüsselpaare auf Chipkarte – Fortgeschrittene elektronische Signatur	RDH ist die Abkürzung für RSA-DES-Hybridverfahren und ist eine Kombination aus dem symmetrischen DES-Verschlüsselungsverfahren und dem asymmetrischen RSA-Verfahren, das nach seinen drei Erfindern Rivest, Shamir und Adleman benannt wurde. Dabei werden Schlüsselpaare verwendet, die aus einem öffentlichen und einem privaten Schlüssel bestehen. Der private Schlüssel des Kunden befindet sich auf der Chipkarte, dort können auch öffentliche Schlüssel des Finanzinstitutes abgelegt werden. Der Kunde signiert Anmelde- oder Transaktionsdaten mit seinem geheimen privaten Schlüssel und das Finanzinstitut entschlüsselt sie mit dem zugehörigen öffentlichen Schlüssel und kann so die Unverfälschtheit (Integrität) der Daten und den Absender überprüfen. Die Echtheit der erhaltenen öffentlichen Schlüssel wird vom Empfänger anhand eines mitgelieferten Zertifikats überprüft. Die Anwendung des Verfahrens ist identisch zum DES-DES-Verfahren, die kryptographischen Verfahren werden ebenfalls auf der Chipkarte durchgeführt. Im Unterschied zum DDV-Verfahren wird der private Schlüssel beim Kunden auf der Chipkarte erzeugt. Damit ist die Herkunft einer Kundensignatur über das Zertifikat eindeutig nachweisbar, da der Kunde allein über den privaten Schlüssel verfügt.

(Fortsetzung)

Tab.2.2 (Fortsetzung)

Signaturbasierte HBCI-Verfahren	
RDH in Dateiform – Schlüsselpaare in Dateiform – Fortgeschrittene elektronische Signatur	In dieser Form des RDH-Verfahrens liegen die Schlüssel als Datei vor, die auf einem USB-Stick, einer Festplatte oder einem anderen Datenträger gespeichert werden kann. Der Zugriff auf die Schlüssel ist durch eine PIN geschützt. Die Anwendung durch den Kunden ist im Ablauf mit folgender Abweichung identisch zu den chipkartenbasierten RDH-Verfahren: Anstatt die Chipkarte in das Kartenlesegerät einzuführen, muss der Kunde den Datenträger einlegen beziehungsweise anschließen und ggf. auch die Schlüsseldatei auf dem Medium manuell auswählen. Anschließend werden die kryptographischen Verfahren auf dem Kunden-PC durchgeführt.

Für die beiden Gruppen von Sicherungsverfahren existieren unterschiedliche Einsatzvoraussetzungen. Während PIN/TAN-Verfahren ohne zusätzliche Software im browserbasierten Online-Banking und unter Verwendung von Apps eingesetzt werden können, erfordern die HBCI-Signaturverfahren entweder den zusätzlichen Einsatz von Finanzsoftware oder institutseigener Software, wie z.B. Browsererweiterungen (Plug-Ins).

2.2 Die Verbreitung der Sicherungsverfahren seit 2008

Die Verbreitung dieser Verfahren wird seit 2008 jährlich von der Initiative D21 und der Fiducia IT AG in einer repräsentativen Umfrage unter Internetnutzern ermittelt (Initiative D21 e.V. und Fiducia IT AG 2014). Beim Vergleich dieser Studien ist zu berücksichtigen, dass für die „Nutzung von Sicherheitstechniken“ 2014 abweichend nur die Online-Banking-Nutzer als Basis für die Berechnung der Anteile verwendet wurden und nicht, wie in den Vorgängerstudien, alle befragten Internetnutzer. Die Zahlen von 2014 wurden hier auf die Gesamtheit aller befragten Internetnutzer bezogen, um eine Vergleichbarkeit mit den Zahlen der vorangegangenen Jahre herzustellen. Diesen Studien zufolge stieg der Anteil der Nutzer von HBCI-Verfahren unter den befragten Internetnutzern von 2010 bis 2014 zwar von 6,1 auf 9,1 Prozent; sie blieben jedoch die mit Abstand am seltensten benutzten Verfahren (Tab.2.3). Bei den PIN/TAN –Verfahren blieb das SMS-TAN-Verfahren mit 33,6 Prozent das am häufigsten genutzte Sicherungsverfahren, kurz gefolgt vom ChipTAN-Verfahren mit 26,4 Prozent (manuelle Eingabe und optische Übertragung mit Flickercode). Demgegenüber ging die Nutzung des iTAN-Verfahrens von 38 Prozent auf 15,1 Prozent stark zurück.

Die Abb. 2.1 verdeutlicht die Entwicklung der Nutzungszahlen graphisch. Die Nutzung der iTAN fällt von 45 Prozent 2009 innerhalb von drei Jahren auf 17 Prozent stark ab und sinkt danach nur noch leicht auf 15 %. Parallel dazu steigt die Nutzung des SMS-TAN-Verfahrens stark an, sinkt in 2011 etwas und liegt seitdem kontinuierlich zwischen 31 und

Tab.2.3 Verbreitung ausgewählter Sicherungsverfahren im Online Banking auf der Basis der Umfrage der Initiative D 21 und Fiducia IT von 2008 bis 2012 und 2014 sowie Häufigkeit des Angebots

Sicherungs- verfahren	Nutzung in % der Internetnutzer in Deutschland ab 14 Jahre ^a						Angebot auf 30 Webseiten ^c
	2008	2009	2010	2011	2012	2014 ^b	2014
iTAN	44,7 %	45,6 %	38,0 %	32,9 %	17,0 %	15,1 %	15
SMS-TAN	24,1 %	34,3 %	35,3 %	32,5 %	31,0 %	31,7 %	28
ChipTAN (Sm@rtTAN, Sm@rtTAN plus)	4,4 %	5,0 %	5,1 %	12,3 %	28,0 %	26,4 %	17
HBCI	5,6 %	6,0 %	6,1 %	6,8 %	11,0 %	9,1 %	16

^alt. Umfragen der Initiative D 21 und Fiducia IT; Varianten desselben Verfahrens wurden zusammengefasst. Mehrfachantworten waren möglich, die Antwortmöglichkeiten „Keines der genannten“ bzw. „Weiß nicht“ oder „keine Angabe“ wurden in den Studien vor 2014 erfasst, aber nicht mit ausgewiesen und sind aus diesem Grund hier nicht aufgeführt

^bBasis „Alle Befragten“ der Studie, analog zu den Vorgängerstudien

^cEigene Erhebung

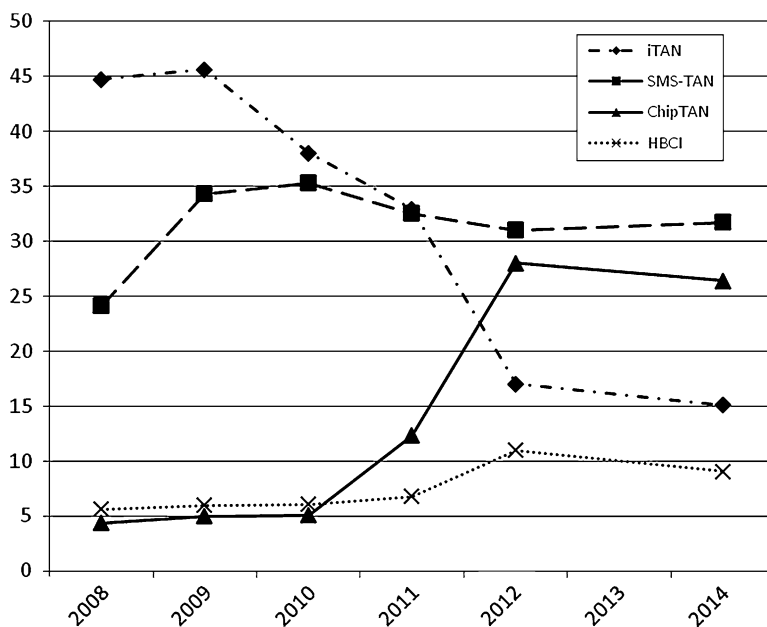


Abb.2.1 Entwicklung der Nutzungszahlen der Sicherungsverfahren im Online-Banking auf der Basis der Umfrage der Initiative D 21 und Fiducia IT von 2008 bis 2014; *) Basis „Alle Befragten“ der Studie, analog zu den Vorgängerstudien

32 Prozent. Die Verbreitung des ChipTAN-Verfahrens stieg, von 2010 bis 2012 in nur zwei Jahren von fünf auf 28 Prozent und sank 2014 leicht.

Die unterschiedliche Nutzung hängt auch davon ab, von wie vielen Instituten die Verfahren angeboten werden und wie gut sichtbar dies geschieht. In einer eigenen Analyse wurden daher die Webseiten der beliebtesten 30 Geldinstitute diesbezüglich verglichen (vgl. Kap. 8 sowie Diederich (2015)). Dabei zeigte sich, dass 2014 nur 16 der 30 Institute Informationen zu HBCI-Verfahren angeboten haben, gegenüber 28 mit Informationen zu SMS-TAN, 17 zu ChipTAN und 15 zu iTAN (Tab. 2.3, Spalte Angebot).

Bei den HBCI-Sicherungsverfahren ist allerdings zwischen dem direkt sichtbaren Angebot der Verfahren an Kunden über die Webseite und dem indirekten Angebot über die Unterstützung entsprechender Schnittstellen für Finanzsoftware zu unterscheiden, das von außen nicht erkennbar ist. So führt z. B. die Subsemlby GmbH in ihrer Liste von 3066 Banken mit HBCI- oder FinTS-Zugang 102 Banken auf, die über die PIN/TAN-Erweiterung des HBCI-Standards die klassische TAN-Liste unterstützen, 473 Banken für das iTAN-Verfahren, 2249 Banken für das SMS-TAN-Verfahren, 1976 Banken für das ChipTAN-Verfahren und 3058 Banken unterstützen mindestens ein HBCI-Signaturverfahren. Die Studien der Initiative D21 berücksichtigen diesbezüglich der Verbreitung der Verfahren insofern, als für HBCI-Sicherungsverfahren der Einsatz einer Software als Voraussetzung genannt wird (Initiative D21 e.V. und Fiducia IT AG 2014). Umgekehrt wird ein Einsatz von PIN/TAN-Verfahren bereits im HBCI-Standard selbst berücksichtigt, durch die eigens dafür geschaffene PIN/TAN-Erweiterung des Standards.

2.3 Sicherheitsbewertung der Verfahren

Finanzinstitute wissen und Kunden ahnen zumindest, dass die genannten Sicherungsverfahren unterschiedlich sicher sind. Aber die Kunden sind sich nicht sicher, wie man diese möglichst objektiv bewerten und genauer unterscheiden kann. Sie orientieren sich vermutlich an den Informationen ihres Finanzinstituts sowie im persönlichen Umfeld. Die meisten Finanzinstitute bieten zwar mehrere Verfahren an, vermeiden jedoch in der Regel bewusst jeden Hinweis auf unterschiedliche Sicherheitsniveaus und stellen die Verfahren somit de facto als gleich sicher dar. Hinweise auf unterschiedliche Sicherheit finden die Kunden in den Medien, besonders in der Presse, im Internet und im Fernsehen. Diese sind allerdings nicht einheitlich, wie die folgende Auswahl zeigt:

Beispiele

- Das Bundesamt für Sicherheit in der Informationstechnik (o.J.) und Schmidt (2014) in der Zeitschrift chip heben hervor, dass bei allen PIN/TAN-Verfahren die größte Gefahr darin besteht, dass Angreifer PIN und TAN in Erfahrung bringen können und stellen Signaturverfahren als sicherere Alternative dar. Schmidt bezeichnet HBCI mit

Chipkarte als „stationäres Verfahren“ und sieht darin den Grund dafür, dass Nutzer auf unsicherere Verfahren ausweichen.

- n-tv (2014) zitiert einen Experten, der ebenfalls HBCI mit Signaturkarte für deutlich sicherer hält, aber über den Preis hinaus darauf hinweist, „dass es aufwendig zu installieren ist, [...] man braucht eine Software, die kostet Geld, auch die Kartenleser sind relativ teuer, man muss da etwa 50 Euro einplanen. Es ist deutlich aufwendiger, aber man kriegt halt wieder einen Tick mehr Sicherheit.“
- Stern Online bezeichnet iTAN-Verfahren als „überholt“, ChipTAN, SMS-TAN, PushTAN und das chipkartenbasierte HBCI-Verfahren hingegen als „aktuell“. Für die PIN/TAN-Verfahren werden ausschließlich technische Risiken geschildert, gegen das HBCI-Verfahren wird angeführt, dass es vor allem von Firmen genutzt wird, „recht veraltet“ ist und hohe Kosten von „bis zu 100 Euro“ fällig werden (stern 2013).
- Die Zeitschrift Focus schreibt: Die bekanntesten Sicherungsverfahren sind ChipTAN, smart-TAN mit optischer Übertragung, Photo-TAN, mobile TAN und HBCI-Banking mit Chipkarte und Lesegerät. Lediglich dem smart-TAN-Verfahren, einer Variante des ChipTAN-Verfahrens, wird explizit ein guter Schutz bescheinigt. Der Artikel schließt aber damit, dass die Experten Online-Banking mit HBCI empfehlen und nennt den Preis für den Kartenleser („zwischen 50 und 160 Euro“) als einziges Negativkriterium (Schickling 2014).
- Eggeling (2014) in der PC-Welt sowie Ries und Kossel (2014) im c't Magazin stufen ChipTAN als sicherstes Verfahren ein, SMS-TAN als relativ sicher und gedruckte TAN-Listen als unsicherstes Verfahren. Während Eggeling HBCI-Verfahren unberücksichtigt lässt, bewerten Ries und Kossel HBCI mit Chipkarte nur in einer Abbildung zum Artikel kurz als „fast ausgestorben, da nicht Browser-tauglich“ und nicht völlig sicher, „da das Lesegerät keine Transaktionsdaten anzeigt“ (Ries und Kossel 2014). Diese Bewertung lässt, trotz nebenstehender Abbildung eines Kartenlesegerätes mit eigener Anzeige, außer Acht, dass es Kartenlesegeräte gibt, auf denen Transaktionsdaten angezeigt werden können.

Mit Ausnahme der Bewertung der HBCI-Verfahren durch Ries und Kossel (2014) lässt sich eine Tendenz dahin gehend erkennen, dass dem iTAN-Verfahren die geringste und den HBCI-Verfahren die höchste Sicherheit zugeschrieben wird, während die Bewertung von SMS-TAN und ChipTAN etwas variiert. Dies zeigt sich auch bei der Stiftung Warentest. Während Finanztest 2003 neben HBCI mit Chipkarte oder Datenträger auch PIN mit TAN-Liste noch als ausreichend sicher beurteilt hat (Stiftung Warentest 2003), werden 2013 TAN-Liste und iTAN nicht mehr empfohlen. Dieser Test nennt ChipTAN, die chipkartenbasierte Signatur (bezeichnet als FinTS) und SMS-TAN als sicherere und am häufigsten genutzte Verfahren. Dabei werden ChipTAN und Signatur beide gleichermaßen als „sehr sicher“ und SMS-TAN nur als „sicher“ bewertet (Stiftung Warentest 2003).

Bei diesen Bewertungen wird allerdings nicht deutlich, nach welchen Kriterien und mit welcher Metrik die Bewertung erfolgt. Wissenschaftliche Studien gehen in der Regel von definierten Bedrohungsszenarien oder Angriffen aus und bewerten, wie gut Verfahren

geeignet sind, diese abzuwehren oder den Schaden zu begrenzen (z. B. Borges et al. 2011). Im Detail gibt es dabei durchaus Unterschiede.

So identifiziert eine Studie der European Union Agency for Network and Information Security (ENISA) elf verschiedene Bedrohungen im Sinne von Angriffen (Attacks) auf ein Bankkonto beziehungsweise das Guthaben des Kunden und fasst diese zu vier Gruppen zusammen (Medina et al. 2013):

- Angriffe auf den Nutzer selbst, z.B. Diebstahl von Sicherheitselementen wie TAN-Listen, Chipkarten, oder Täuschung zur Herausgabe von Geheimnissen (z.B. durch Phishing)
- Angriffe auf Sicherheitselemente des Nutzers, z. B. durch Schadsoftware auf dem PC oder Mobiltelefon,
- Angriffe auf die Übertragungswege
- Angriffe auf die IT-Infrastruktur der Finanzinstitute.

Je mehr Angriffe mit einem Sicherungsverfahren abgewehrt und/oder je stärker ihre Auswirkungen reduziert werden können, desto sicherer ist das Verfahren. Diese Vorgehensweise ermöglicht zusätzlich die Erkennung von Restrisiken, denen mit verfügbaren Maßnahmen nicht oder nur unzureichend entgegengewirkt werden kann.

ENISA hat 2013 rund 100 Fachleute (Professionals) im Bereich E-Payment in der EU um eine Beurteilung der Stärke der verschiedenen Sicherungsverfahren in Bezug auf diese Bedrohungen gebeten. Danach schneiden chipkarten- und dateibasierte Signaturverfahren am besten ab, gefolgt von SMS-TAN und ChipTAN-Verfahren, während Benutzername und Passwort, mobile Online-Banking Anwendungen sowie TAN-Listen das Schlusslicht bilden (Medina et al. 2013).

Das EU-Projekt STORK bewertet den gesamten Prozess der Erzeugung, Ausgabe und Nutzung von Sicherungselementen zur Authentisierung von Personen und Transaktion im Hinblick auf das Ausmaß an Vergewisserung für die empfangende Stelle, in unserem Fall das Finanzinstitut, und definiert dafür vier verschiedene Vergewisserungsstufen (Hulsebosch et al. 2009). Teil dieser Bewertung ist auch die Sicherheitsqualität der Authentifizierungsverfahren, deren Anforderungen in der Tab. 2.4 aufgeführt sind und ebenfalls auf vier Stufen eingeordnet werden.

Die hier betrachteten Sicherungsverfahren im Online-Banking lassen sich gut diesen Qualitätsstufen zuordnen:

- Die iTAN-Liste stellt de facto eine Passwortliste dar; die Länge der Passwörter entspricht nicht dem aktuellen Standard, auch wenn eine Begrenzung der Anzahl von Versuchen zusätzlichen Schutz bietet und wird dementsprechend der Stufe 1 zugeordnet.
- Das SMS-TAN-Verfahren verwendet eine serverseitig generierte TAN als Einmalpasswort und kann entsprechend zusammen mit TAN-Generatoren, wie z.B. dem ChipTAN-Verfahren, der Stufe 3 zugeordnet werden.

Tab.2.4 Sicherheitsqualität der Authentifizierungsverfahren nach STORK (Hulsebosch et al. 2009 in eigener Übersetzung)

Anforderungen	Qualitätsstufen nach Art und Robustheit der Nachweise ^a			
	1	2	3	4
Passwort oder PIN-basiertes Autorisierungsmittel, ausgewählt vom Antragsteller oder automatisch generiert und <i>nicht konform</i> zu allgemein anerkannten Richtlinien für starke Passwörter oder PINs (z. B. unzureichende Länge, kein Zeichenmix, Wiederverwendung, etc.) und somit verwundbar durch Erraten oder Wörterbuchattacks	●			
Passwort oder PIN-basiertes Autorisierungsmittel, ausgewählt vom Antragsteller oder automatisch generiert aber <i>konform</i> zu allgemein anerkannten Richtlinien für starke Passwörter oder PINs (z. B. ausreichende Länge, Zeichenmix, keine Wiederverwendung, etc.) und somit <i>nicht</i> verwundbar durch Erraten oder Wörterbuchattacks	●	●		
Softwarebasierte Zertifikate oder Autorisierungsmittel zur Generierung von Einmalpasswörtern	●	●	●	
Qualifizierte softwarebasierte Zertifikate gemäß Annex I der Direktive 199/93/EC	●	●	●	
Hardwarebasierte Zertifikate	●	●	●	
Qualifizierte hardwarebasierte Zertifikate gemäß Annex I der Direktive 199/93/EC	●	●	●	●

^a1 = niedrigste Qualitätsstufe, 4 = höchste Qualitätsstufe

- Das dateibasierte HBCI-Signaturverfahren ist ein softwarebasiertes Zertifikat (ebenfalls Stufe 3).
- Die höchste Qualitätsstufe 4 erreicht das chipkartenbasierte HBCI-Signaturverfahren, wenn Chipkarte und Kartenleser den Anforderungen an qualifizierte Signaturen entsprechen.

Diesen vier Sicherheitsstufen wurden die Ergebnisse verschiedener Bewertungsansätze in den Medien, der Stiftung Warentest und der ENISA-Studie zugeordnet, um sie vergleichen zu können (siehe Tab. 2.5). Wie schon bei der Zusammenfassung der Rangfolgen mit dem iTAN-Verfahren auf der niedrigsten und den HBCI-Verfahren auf dem höchsten Sicherheitsniveau.

Darauf können wir als unumstrittene Grundlage aufbauen, wenn wir in den folgenden Kapiteln die Entwicklung chronologisch und gestützt auf unsere Interviews mit Verbandsvertretern schildern. Dabei geht es zunächst um die Pläne, das als unsicher geltende PIN/TAN-Verfahren mit einfachen oder indizierten TAN-Listen durch die als deutlich sicherer geltenden signaturbasierten HBCI-Verfahren abzulösen und damit einen

Tab.2.5 Sicherheitsranking nach verschiedenen Quellen

Sicherungsverfahren	Tendenz in den Medien 2014	Stiftung Warentest 2013	ENISA-Studie	Robustheit nach STORK
iTAN	2	2	1	1
SMS-TAN	3	3	3	3
ChipTAN	4	4	3	3
HBCI	4	4	4	4

grundsätzlichen Paradigmenwechsel zu vollziehen. Inwieweit die später eingeführten Varianten innerhalb des PIN/TAN-Paradigmas mit den HBCI-Verfahren gleichziehen können, wird unterschiedlich eingeschätzt und von uns nach einem eigenen Ansatz in Kap. 5 näher analysiert. Dabei bewerten wir die Verfahren nach ihren Sicherheitsleistungen, den verwendeten Autorisierungsmittel (TANs oder digitale Zertifikate), der Möglichkeit zur Kontrolle der Transaktionsdaten vor der Autorisierung, der Verknüpfung von Transaktionsdaten mit Autorisierungsmerkmalen sowie der Robustheit gegen Angriffe, insbesondere gegen Schadsoftware.

2.4 Verbreitung und Sicherheit im Verhältnis

Stellt man die Sicherheitsbewertungen aus Tab. 2.5 den Verbreitungszahlen für die genannten Verfahren gegenüber, so zeigt sich, dass sich das Verhältnis von Sicherheit und Verbreitung im Lauf der letzten Jahre verändert hat. Das am wenigsten sichere iTAN-Verfahren war zwar 2010 noch das am häufigsten genutzte. Nachdem die mangelnde Sicherheit immer deutlicher wurde (und die Schäden vermutlich gerade bei diesem Verfahren zugenommen haben), wurden Alternativen entwickelt und stärker beworben, so dass die Nutzung und zuletzt auch das Angebot zurückgingen (vgl. Abb. 2.2).

In Bezug auf das Verhältnis der anderen PIN/TAN-Verfahren zu HBCI bestätigt sich das erwartete Spannungsverhältnis hingegen bis heute. Die HBCI-Verfahren werden als die sichersten angesehen, aber deutlich seltener angeboten und noch weniger genutzt als SMS- und ChipTAN.

Zu diesem Ergebnis kommt auch die erwähnte ENISA-Studie. Deren Autoren stellen zusammenfassend fest, dass ihre Befragungsergebnisse den weitverbreiteten Eindruck bestätigen, dass der Finanzsektor bei der Auswahl der Authentisierungsmethoden der Benutzbarkeit Priorität einräumt vor anderen Kriterien (Medina et al. 2013). Das war vor knapp 30 Jahren beim Abschluss des HBCI-Abkommens anders.

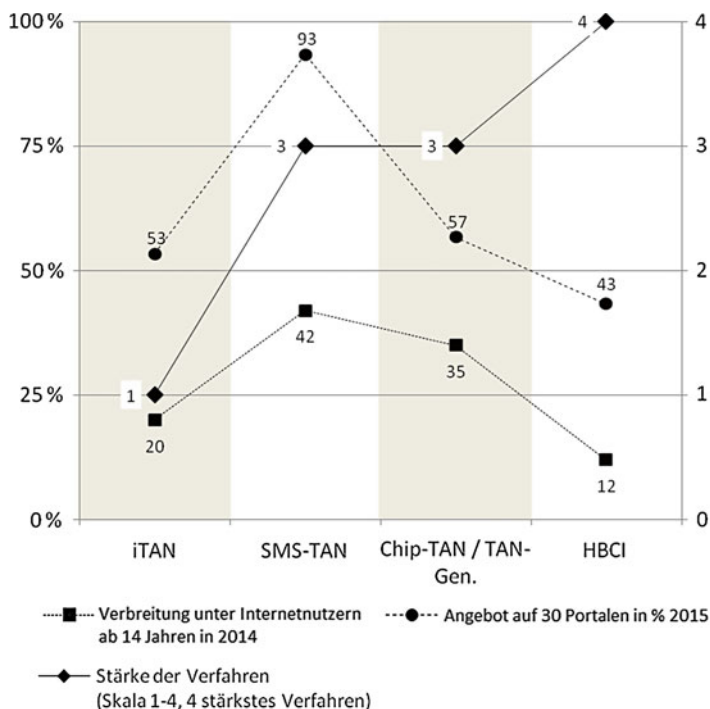


Abb.2.2 Stärke, Angebot und Nutzung der Sicherungsverfahren

Literatur

- BayLfSt (o.J.) Signaturkarten für Authentifizierung. <https://www.elsteronline.de/eportal/UnterstuetzteSignaturkarten.tax>. Abruf am 2015-06-19.
- Borges G, Schwenk J, Stuckenberg C, Wegener C (2011) Identitätsdiebstahl und Identitätsmissbrauch im Internet: Rechtliche und technische Aspekte. Springer Berlin Heidelberg.
- Deutsche Kreditwirtschaft (2015) FinTS. <https://www.hbci-zka.de/>. Abruf am 2015-06-19.
- Diederich G (2015) Sicherheit und Entwicklung der Authentisierung im Online-Banking in Deutschland aus der Perspektive der Banken. In Vorbereitung.
- Eggeling T (2014) Maßnahmen für sicheres Online-Banking. http://www.pcwelt.de/ratgeber/Massnahmen_fuer_sicheres_Online-Banking_-Online-Sicherheit-8595460.html. Abruf am 2015-06-19.
- Hulsebosch B, Lenzini G, Eertink H (2009) Quality Authenticator Scheme. Project STORK - Secure Identity Across Borders Linked. B. Hulsebosch, G. Lenzini, and H. Eertink. https://www.eid-stork.eu/index.php?option=com_processes&Itemid=&act=streamDocument&did=577. Abruf am 2015-06-19.
- Initiative D21 e.V., Fiducia IT AG (2014) Online-Banking 2014 Sicherheit zählt! Wünsche und Anforderungen an Bankgeschäfte im Internet. http://www.initiaved21.de/wp-content/uploads/2014/07/d21_fiducia_studie_onlinebanking_2014.pdf. Abruf am 2015-06-19.

- Medina M, Serna J, Sfakianakis A, Aguilá J, Fernández LÁ (2013) eID authentication methods in e-finance and e-payment services. Current practices and recommendations, European Union Agency for Network and Information Security (ENISA). <https://www.enisa.europa.eu/activities/identity-and-trust/library/deliverables/eIDA-in-e-finance-and-e-payment-services>. Abruf am 2015-06-19.
- n-tv Nachrichtenfernsehen GmbH (2014) Bezahlverfahren im Sicherheitscheck: Tipps für sicheres Online-Banking - n-tv.de. <http://www.n-tv.de/ratgeber/Sendungen/Tipps-fuer-sicheres-Online-Banking-article12476096.html>. Abruf am 2015-06-19.
- Ries U, Kossel A (2014) Augen auf beim Online-Banking. Über Schutz vor Schäden und die Haftung, falls er versagt. c't magazin für computertechnik(25):80–82.
- Schickling T (2014) Schutz bei Internet-Überweisungen: Sicheres Online-Banking - So schützen Sie Ihr Geld vor Cyber-Gangstern - Sicherheit im Online-Banking. http://www.focus.de/finanzen/banken/Online-Banking-fest-verriegelt_id_3815131.html. Abruf am 2015-06-19.
- Schmidt C (2014) Online-Banking: Sicher dank Chipkartenleser. http://www.chip.de/news/Onlinebanking-Sicher-dank-Chipkartenleser_66633566.html. Abruf am 2015-06-19.
- stern.de GmbH (2013) Online-Banking: Das sollten Sie über die verschiedenen TAN-Verfahren wissen. <http://www.stern.de/tv/sterntv/Online-Banking-das-sollten-sie-ueber-die-verschiedenen-tan-verfahren-wissen-2072472.html>. Abruf am 2015-06-19.
- Stiftung Warentest (2003) Traue keinem unter 128. Finanztest(9):24–27. <https://www.test.de/Sicherheit-beim-Online-Banking-Traue-keinem-unter-128-1117863-0/>. Abruf am 2015-06-19.
- Zöhrer M (2010) Sicherheitsaspekte im Online-Banking: Autorisierungsverfahren im Spannungsfeld zwischen Usability und Sicherheit. VDM Verlag Dr. Müller.